TASK: 29

Insecure Authentication & Authorization

&

Insecure Communication

Surendra Gabbani

What is Insecure Authentication?

Authentication is the process of confirming who the user is.
When authentication is insecure, the system fails to properly verify the user, making it easy for attackers to break in.

Common Issues:

Authentication becomes insecure when:

- Weak or predictable passwords
- No multi-factor authentication (MFA)
- Passwords stored in plain text
- Poor session management
- Missing account lockout policies

What is Insecure Authorization?

Authorization decides what actions a user can perform *after* they are logged in.
When authorization is insecure, the system doesn't properly enforce permissions, allowing attackers to access or modify data they should not.

Common Issues:

- IDOR (Insecure Direct Object Reference)
- Missing role checks (normal user accessing admin features)
- Horizontal privilege escalation (accessing other users' data)
- Vertical privilege escalation (gaining admin-level access)
- Client-side authorization checks that can be bypassed

Real-World Impact:

Insecure auth & authorization can lead to:

- Account takeover
- Unauthorized data access
- Financial fraud
- Leakage of personal & corporate information
- Full system compromise

Common Examples:

1. Weak Password Policy

- “admin/admin”, “123456”
- No password complexity

2. Missing Access Check

- Anyone can view another user’s profile using: /user?id=102

3. Session Hijacking

- Tokens not rotated
- Session IDs in URLs

4. Privilege Escalation

- Normal user becomes admin due to missing role checks.

How Attackers Exploit:

- Brute-force login
- Password spraying
- API calls without access control
- Manipulating parameters (IDOR)
- Using stolen cookies or tokens

Prevention & Best Practices:

Authentication

1. Strong password policy
2. Enforce MFA
3. Secure password hashing (bcrypt/argon2)
4. Account lockout after failed attempts
5. CAPTCHA for bot protection

Authorization

1. Implement proper RBAC/ABAC
2. Server-side access checks only
3. Validate every user action
4. Protect APIs with scopes/roles
5. Least privilege principle

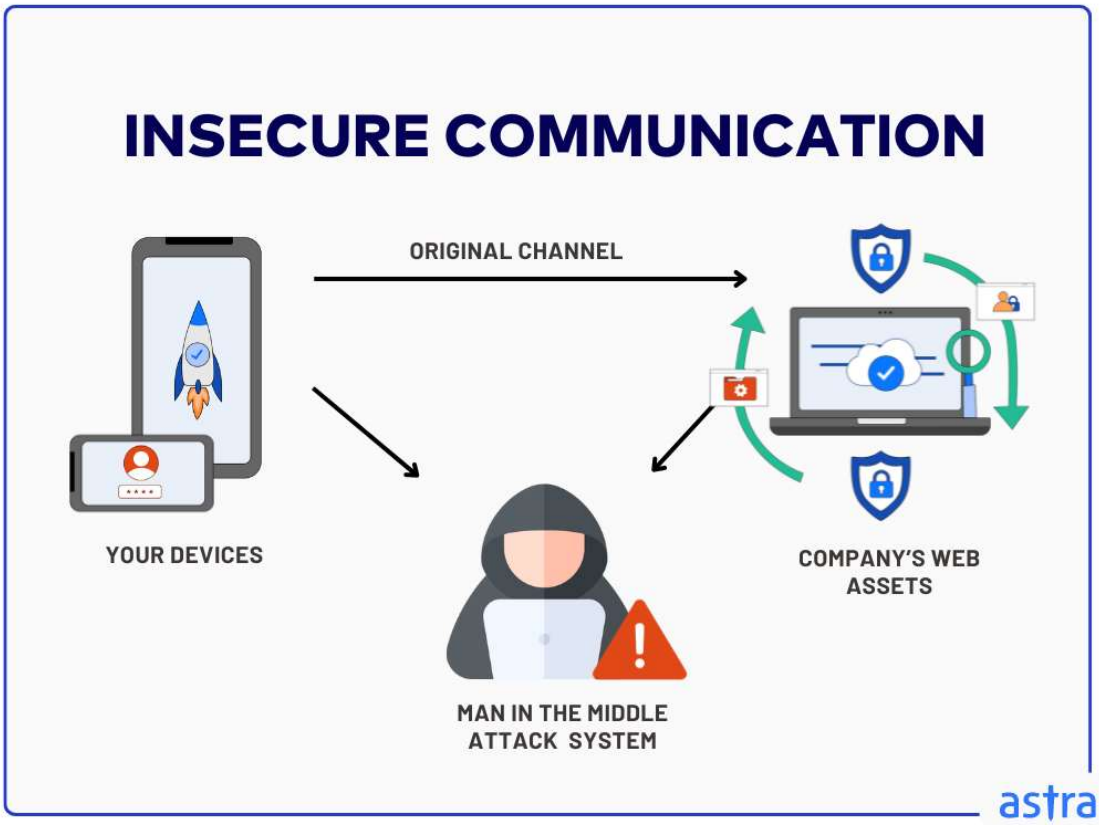
What is Insecure Communication?

Insecure Communication refers to any situation where data is transmitted between a client (mobile app, web browser, API) and a server without proper security controls, especially encryption. Insecure Communication occurs when data is transmitted without proper encryption or validation, allowing attackers to intercept, read, or modify the information.

Examples of Insecure Communication:

- A website sending login credentials via HTTP
- Mobile apps that accept any SSL certificate (easy MITM attack)
- API endpoints returning sensitive data without encryption
- Applications exposing tokens in URL parameters
- Apps communicating with outdated TLS protocols
- Public Wi-Fi users having their traffic sniffed

IoT devices sending data unencrypted over the network.



Causes:

- Using HTTP instead of HTTPS
- Weak or outdated encryption
- No certificate validation
- Accepting invalid or self-signed certificates
- Missing SSL/TLS pinning
- Sensitive data sent in plain text
- Misconfigured servers or insecure networks.

Risks & Impact:

- Data interception (MITM attacks)
- Credential theft
- Session hijacking
- Pivacy leakage
- API and backend compromise
- Regulatory non-compliance (GDPR, PCI-DSS)

Prevention:

- Use HTTPS with strong TLS versions
- Implement HSTS
- Validate all certificates
- Apply SSL/TLS pinning
- Encrypt sensitive data before sending
- Secure API keys and update them often
- Use VPNs on public networks
- Conduct regular security reviews

Frida

What is Frida?

- Frida is a dynamic instrumentation toolkit used for security testing, reverse engineering, debugging, and runtime analysis of applications.
- Think of it as a powerful tool that lets you inject your own scripts into running apps on Android, iOS, Windows, macOS, and Linux.

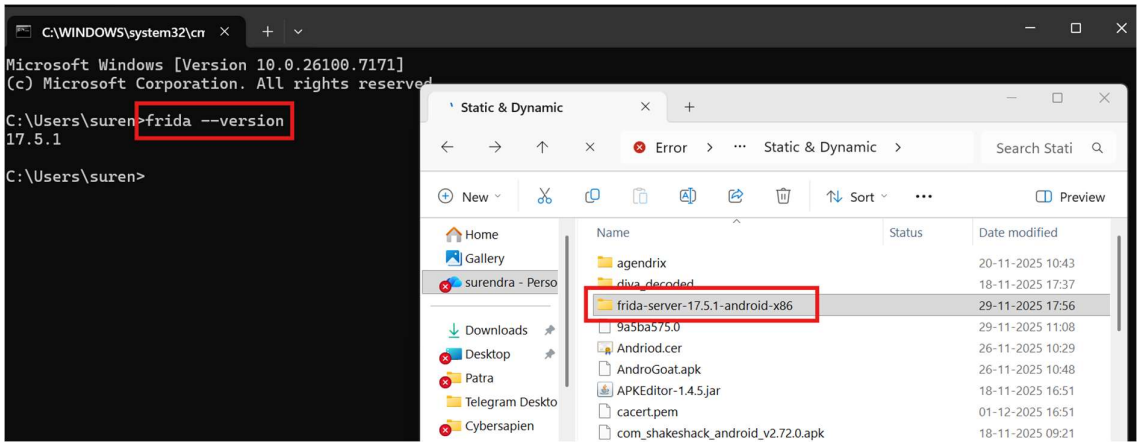
LAB PRACTICAL

Find the practical lab of Frida server setup.

Lab APK: Frida server in android emulator.

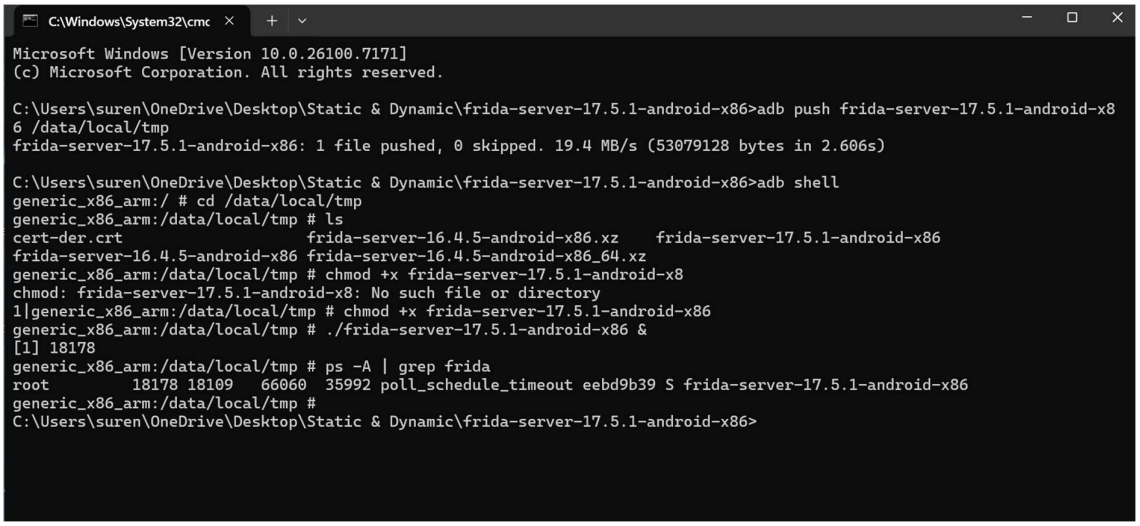
STEP 1:

- Open command prompt download and check Frida version and download the same version Frida apk.



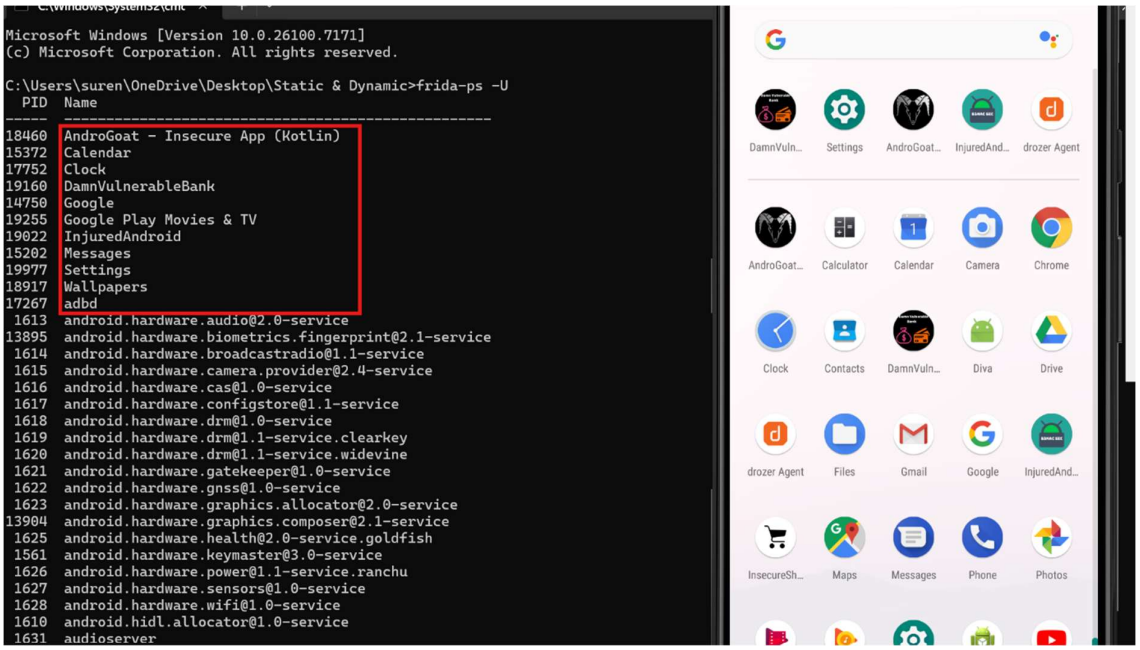
STEP 2:

- Run these commands listed below to setup frida.
- These commands together help you install Frida, run it on device, list apps, hook a target app, and bypass SSL pinning.



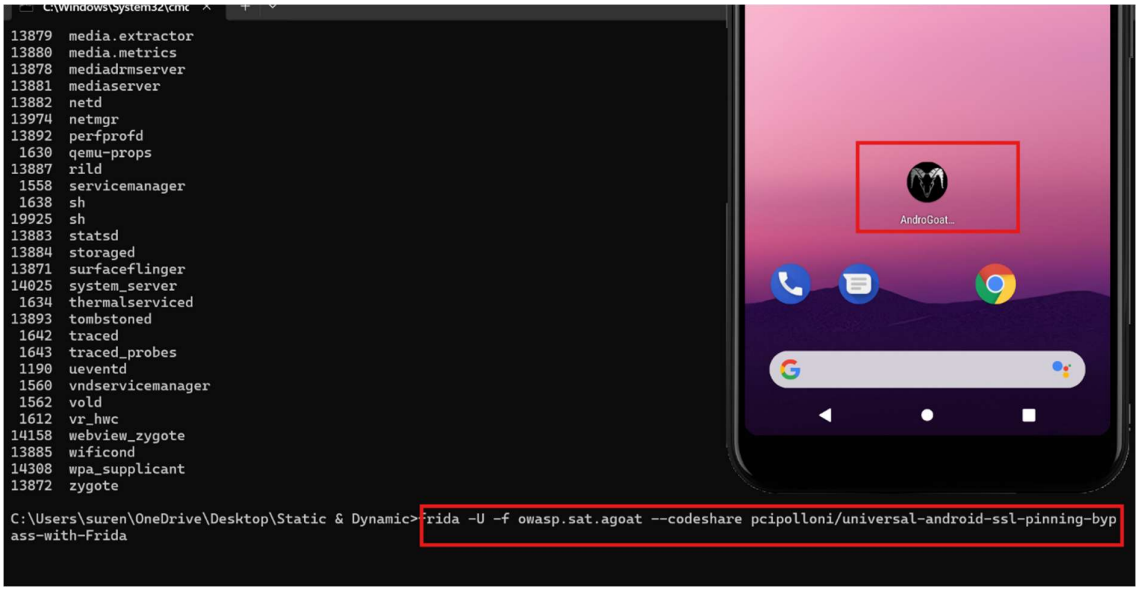
STEP 3:

- From your PC → lists all apps on the connected emulator device.



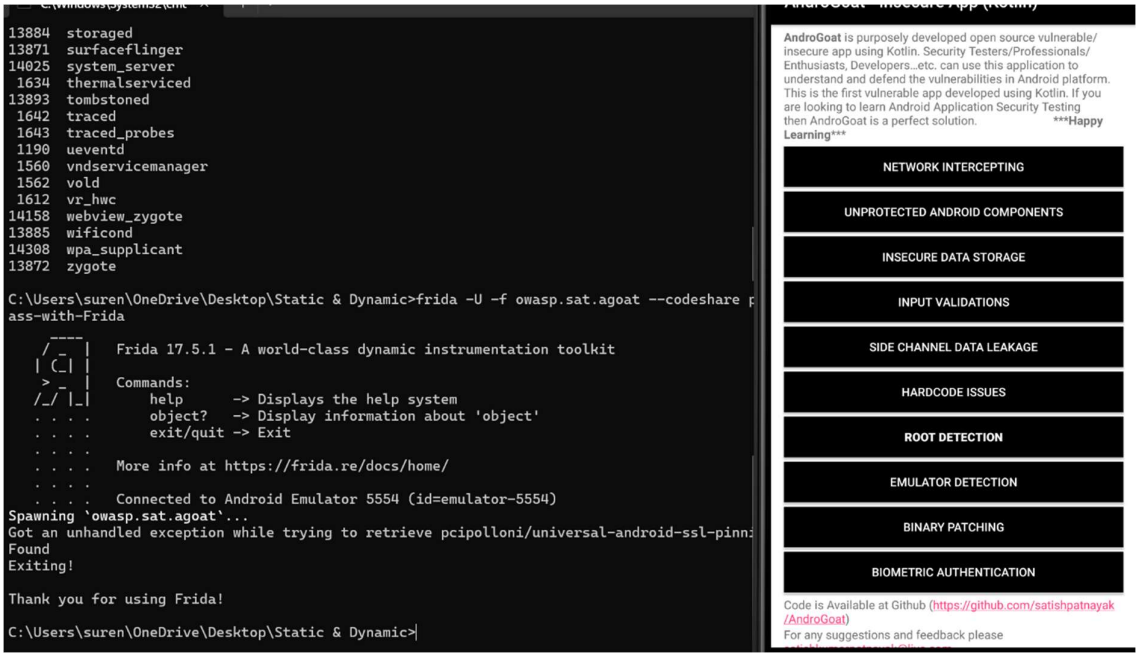
STEP 4:

- Runs the andriodgoat app with SSL Pinning bypass.
- “rida -U -f owasp.sat.agoat --codeshare pcipolloni/universal-android-ssl-pinning-bypass-with-Frida “



STEP 5:

- Here , successfully bypass the android apk in emulator by using Frida.
- This is used to **bypass SSL Pinning** in Android apps.



Conclusion:

- Weak communication channels and poor authentication or authorization controls create serious security risks that attackers can easily exploit. Insecure communication exposes data during transmission, while flawed authentication allows unauthorized users to log in, and improper authorization grants them access to sensitive functions or information.
- To protect systems and users, strong encryption, reliable identity verification, and strict access control must all work together. Implementing secure protocols, enforcing multi-factor authentication, validating user permissions, and regularly testing these security layers helps prevent data breaches, unauthorized access, and application compromise. Ensuring these three areas are properly secured is essential for building safe, trustworthy, and resilient applications.

Thank you